Sicherheits- & Datenschutz-Offenlegung, Abschlussbericht

yesss! Android (at.a1telekom.android.yesss)

Die Produktions-Firebase-Datenbank der österreichischen Budget-Mobilfunkmarke yesss! ist unter dem Namen ”educom-6e0db” registriert, weder unter der A1- noch der yesss!-Marke, eine Telekommunikations-App kombiniert zugleich privilegierte Nutzungsdaten mit Werbe-Attribution, einzige Meldung ohne jede Folgenachricht über 109 Tage vollständig unbeantwortet, 19 Tage nach Ablauf des Embargos

ÖFFENTLICHE OFFENLEGUNG, 17. OKTOBER 2026 — EMBARGO ERREICHT AM 28. SEPTEMBER 2026, DREI BEFUNDE UNBEANTWORTET

Zielunternehmen	A1 Telekom Austria AG, Wien (Wiener Börse: A1, ~€4,2 Mrd. Konzernumsatz) — Betreiber der Marke yesss!
Package	at.a1telekom.android.yesss
Analysierte Plattform	Android, statische Analyse der Produktions-APK (~18.000 Smali-Klassen)
Erstmeldung (R1)	2026-06-30 (REF YESSS-2026-R1-001)
Offenlegungs-/Embargo-Datum	2026-09-28
Bericht veröffentlicht	2026-10-17
Gesamtschwere	CRITICAL
Befunde	3 (1 Critical, 2 High)
Korrespondenz	1 Nachricht am 2026-06-30 an datenschutz@a1.at und security@a1.at, 0 Antworten jeder Art, keine Folgenachricht wurde je gesendet, kein Bounce
CC Behörden	Österreichische Datenschutzbehörde (DSB) · Europäischer Datenschutzbeauftragter (EDPS)

security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Gegenstand & Betreiber-Kontext 5

3 Korrespondenz-Zusammenfassung 5

4 Findings 5
4.1 C1: Firebase-API-Key + Produktions-DB "educom-6e0db" hartcodiert — Subunternehmer-Transparenz . . . 5
4.2 H1: ADSERVICES_ATTRIBUTION + AD_ID: Werbeprofiling auf einer Telco-App . 6
4.3 H2: Firebase Pre-Consent-Initialisierung (initOrder=100) — US-Transfer vor Einwilligung . . . 6

5 Impact-Analyse (Impact Analysis) 7

6 Die vollständige Kette (The Complete Chain): Eine Meldung, 109 Tage, keine Folgenachricht, null Antworten 7

7 Datenschutz — Artikel für Artikel (Data Protection) 8

8 Regulatorisches & rechtliches Umfeld (Regulatory) 8

9 Indicators of Compromise 8

10 Offenlegungs-Zeitlinie (Disclosure Timeline) & Ergebnis 9

11 Restrisiko & Empfehlungen (Residual Risk) 9

Executive Summary

yesss! ist die Budget-Mobilfunkmarke der A1 Telekom Austria AG (Wiener Börse: A1, ~€4,2 Mrd. Konzernumsatz). Eine Root-Level-Analyse der Produktions-Android-App (at.a1telekom.android.yesss, ca. 18.000 Smali-Klassen) fand drei Befunde, einen CRITICAL und zwei HIGH.

Der auffälligste Befund ist infrastruktureller Natur: Die Firebase-Produktionsdatenbank der yesss!-App ist unter dem Namen educom-6e0db.firebaseio.com registriert — weder unter der A1- noch der yesss!-Marke. Telekommunikationsdaten österreichischer yesss!-Nutzer fließen damit in eine Infrastruktur, die für die Nutzer nicht als A1- oder yesss!-Infrastruktur erkennbar ist; dies legt entweder eine Subunternehmer-Beziehung (Educom) oder einen geteilten Drittnamespace nahe, ohne dass die Datenschutzerklärung diesen Empfänger oder Subverarbeiter nach Art. 13/Art. 28 DSGVO ausweist (C1). Die App deklariert zugleich ACCESS_ADSERVICES_ATTRIBUTION und ACCESS_ADSERVICES_AD_ID; auf einer Telekommunikations-App, die bereits privilegierte Nutzungsdaten (Tarif, Datenverbrauch, Billing) verarbeitet, bedeutet dies, dass Telco-Nutzungsverhalten mit Werbe-Attribution kombiniert wird (H1). Firebase initialisiert mit initOrder=100 vor dem Einwilligungsbildschirm und überträgt ab der ersten App-Öffnung Daten an Google (USA) (H2).

RFI-IRFOS meldete diese Befunde am 30. Juni 2026 an datenschutz@a1.at und security@a1.at, CC presse@a1.at, die österreichische Datenschutzbehörde (DSB) und den EDPS, mit Embargo-Datum 28. September 2026. Im Unterschied zu allen anderen Fällen dieser Offenlegungs-Serie wurde für diesen spezifischen Fall zu keinem Zeitpunkt eine Folgenachricht gesendet: die Korrespondenzakte besteht ausschließlich aus der Erstmeldung. Über die einzige gesendete Nachricht wurde keine Antwort jeder Art empfangen, kein Bounce registriert.

ID	Severity	Title
C1	CRITICAL	Firebase-API-Key + Produktions-DB ”educom-6e0db” hartcodiert — Subunternehmer-Transparenz
H1	HIGH	ADSERVICES_ATTRIBUTION + AD_ID: Werbeprofiling auf einer Telco-App
H2	HIGH	Firebase Pre-Consent-Initialisierung (initOrder=100) — US-Transfer vor Einwilligung

Gegenstand & Betreiber-Kontext

yesss! ist eine Budget-Mobilfunkmarke der A1 Telekom Austria AG und verarbeitet damit dieselbe Kategorie privilegierter Telekommunikationsdaten (Anrufverhalten, Standorthistorie via Netzwerk-Triangulation, Billing) wie die A1-Hauptmarke selbst, bei entsprechend geringerem öffentlichem Sichtbarkeitsgrad.

Korrespondenz-Zusammenfassung

RFI-IRFOS sendete die Erstmeldung am 30. Juni 2026 an datenschutz@a1.at und security@a1.at, CC presse@a1.at, die österreichische Datenschutzbehörde (DSB) und den EDPS, mit Embargo-Datum 28. September 2026 unter REF YESSS-2026-R1-001. Für diesen Fall wurde über die gesamten 109 Tage bis zur heutigen Veröffentlichung keine Folgenachricht gesendet; die Korrespondenzakte umfasst ausschließlich diese eine Nachricht. Kein Bounce wurde registriert, keine Antwort jeder Art, auch keine automatische Bestätigung, wurde je empfangen.

Findings

C1: Firebase-API-Key + Produktions-DB ”educom-6e0db” hartcodiert — Subunternehmer-Transparenz

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N, 8.0

```
google_api_key:        [REDACTED IN PUBLIC REPORT -- disclosed privately to A1 Telekom
     Austria/yesss! in R1]
firebase_database_url: [REDACTED IN PUBLIC REPORT -- disclosed privately to A1 Telekom
     Austria/yesss! in R1]
  (Firebase-Projektname: "educom-6e0db" -- weder A1- noch yesss!-Markenbezeichnung)
```

Impact: RFI-IRFOS blast-radius escalation: von HIGH/8.0 auf CRITICAL angehoben, weil hier nicht nur ein Key exponiert ist, sondern die Transparenz der gesamten Subverarbeiter-Kette für die Telekommunikations-App einer nationalen Mobilfunkmarke in Frage steht. google_api_key und firebase_database_url sind in res/values/strings.xml hartcodiert und in jeder installierten APK-Kopie enthalten. Besonders auffällig: der Firebase-Projektname lautet educom-6e0db, nicht yesss, a1telekom oder eine vergleichbare Marken-Kennung. Dies legt nahe, dass entweder ein externer Subunternehmer (Educom) die Firebase-Infrastruktur betreibt, oder ein dritter Namespace genutzt wird, ohne dass dies in der Datenschutzerklärung als Empfänger oder Art. 28 DSGVO-Auftragsverarbeiter ausgewiesen ist.

H1: ADSERVICES_ATTRIBUTION + AD_ID: Werbeprofiling auf einer Telco-App

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N, 7.5

```
<uses-permission android:name="android.permission.ACCESS_ADSERVICES_ATTRIBUTION"/>
<uses-permission android:name="android.permission.ACCESS_ADSERVICES_AD_ID"/>
<uses-permission android:name="com.google.android.gms.permission.AD_ID"/>
```

Impact: Die App deklariert ACCESS_ADSERVICES_ATTRIBUTION, ACCESS_ADSERVICES_AD_ID und com.google.android.gms.permission.AD_ID. Eine Telekommunikations-App verarbeitet bereits privilegierte Daten: Tarif-Verwaltung, Datenverbrauch, Billing-Informationen, Vertragsdetails. Die zusätzliche Deklaration der Android Privacy Sandbox Attribution bedeutet, dass Telco-Nutzungsverhalten mit Werbe-Attribution kombiniert wird — ein yesss!-Nutzer, der seinen Tarif verwaltet, generiert dabei Werbekonversionsdaten, ohne dass eine Art. 6(1)-Rechtsgrundlage für diese Zweckänderung in der Datenschutzerklärung erkennbar ist.

H2: Firebase Pre-Consent-Initialisierung (initOrder=100) — US-Transfer vor Einwilligung

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:L/SI:N/SA:N, 7.0

```
com.google.firebase.provider.FirebaseInitProvider -- initOrder=100
Einwilligungssignal vor Initialisierung erfasst: nein
```

Impact: com.google.firebase.provider.FirebaseInitProvider initialisiert mit android:initOrder=100, vor dem Einwilligungsbildschirm. Auf einer Telco-App, die Billing- und Nutzungsdaten verarbeitet, ist die frühzeitige Firebase-Initialisierung besonders relevant: Firebase kann ab der ersten App-Öffnung Gerätedaten, Session-Informationen und anonymisierte Nutzungsdaten an Google (USA) übertragen, bevor der Nutzer irgendeine Einwilligung erteilt hat.

Impact-Analyse (Impact Analysis)

C1 ist der schwerwiegendste Befund, weil er über eine einfache Credential-Exposition hinausgeht und eine konkrete Transparenzfrage zur Subverarbeiter-Kette einer nationalen Telko-Marke aufwirft: Nutzer, die ihrer Telekommunikationsmarke vertrauen, haben keine Möglichkeit zu erkennen, dass ihre App-Daten in einer unter einem dritten Namen (”educom”) registrierten Infrastruktur liegen. H1 verschärft sich durch den Telco-Kontext selbst: Werbeprofiling auf Basis von Tarif- und Nutzungsverhalten berührt eine Datenkategorie, die Nutzer typischerweise nicht mit Werbe-Attribution assoziieren. H2 ist ein konventioneller, aber wiederkehrender Pre-Consent-Gap.

Dieser Fall weicht von allen anderen Fällen dieser Offenlegungs-Serie in einem entscheidenden Punkt ab: über die gesamten 109 Tage bis zur Veröffentlichung wurde zu keinem Zeitpunkt eine Folgenachricht gesendet. Die Korrespondenzakte besteht ausschließlich aus der Erstmeldung vom 30. Juni 2026, und auch diese eine Nachricht blieb vollständig unbeantwortet.

Die vollständige Kette (The Complete Chain): Eine Meldung, 109 Tage, keine Folgenachricht, null Antworten

Schritt 1 — Meldung gesendet: RFI-IRFOS sendet den vollständigen Befundbericht am 30. Juni 2026 an datenschutz@a1.at und security@a1.at, CC presse@a1.at, die österreichische DSB und den EDPS, mit Embargo-Datum 28. September 2026 unter REF YESSS-2026-R1-001.

Schritt 2 — Keine Folgenachricht: Im Unterschied zu allen parallel geführten Fällen dieser Offenlegungs-Serie wurde für yesss! zu keinem Zeitpunkt zwischen dem 30. Juni 2026 und der heutigen Veröffentlichung eine Folgenachricht gesendet. Dies wird hier ausdrücklich und ohne Beschönigung dokumentiert: die Korrespondenzakte besteht aus genau einer Nachricht.

Schritt 3 — Embargo erreicht und überschritten: Das am 30. Juni 2026 einmalig genannte Embargo-Datum verstreicht am 28. September 2026, unverändert durch jede Folgenachricht, da keine gesendet wurde, mit allen drei Befunden unbeantwortet.

Schritt 4 — Veröffentlichung: Dieser Bericht erscheint 19 Tage nach dem Embargo-Datum. Über 109 Tage und eine einzige, nie gebouncte Nachricht an zwei funktionierende Adressen enthält die Korrespondenz null Antworten jeder Art.

Datenschutz — Artikel für Artikel (Data Protection)

Art. 32(1)(b), Art. 13, Art. 28 DSGVO — Sicherheit der Verarbeitung, Transparenz über Empfänger, Auftragsverarbeiter-Kette: C1s unter einem dritten Namen registrierte Firebase-Infrastruktur ist in der Datenschutzerklärung nicht als Subverarbeiter-Beziehung ausgewiesen.

Art. 5(1)(b), Art. 6(1), Art. 13 DSGVO — Zweckbindung, Rechtsgrundlage, Transparenz: H1s Kombination von Telco-Nutzungsdaten mit Werbe-Attribution hat keine erkennbare Rechtsgrundlage für diese Zweckänderung.

Art. 7, Art. 44-49 DSGVO — Bedingungen für die Einwilligung, Drittlandtransfer: H2s Firebase-Initialisierung erfolgt vor jeder Einwilligung und überträgt Daten in die USA.

Regulatorisches & rechtliches Umfeld (Regulatory)

A1 Telekom Austria AG (Wiener Börse: A1) ist der größte Mobilfunkbetreiber Österreichs; yesss! ist dessen Budget-Marke. Die österreichische Datenschutzbehörde (DSB) und der Europäische Datenschutzbeauftragte (EDPS) wurden über die Meldung informiert (DSGVO Art. 83(2)(b)).

Bußgeldrahmen nach DSGVO: Art. 83(4) ist auf alle drei Befunde anwendbar, bis zu 10.000.000 € oder 2 % des weltweiten Konzernjahresumsatzes. Dass ein Mobilfunkkonzern dieser Größenordnung eine einzige schriftliche Meldung über 109 Tage unbeantwortet lässt, ist ein Faktum, das eine Aufsichtsbehörde neben den drei technischen Befunden mit abwägen dürfte.

Indicators of Compromise

Die folgenden Identifikatoren und Manifest-Deklarationen wurden ausschließlich durch statische Analyse der Produktions-APK extrahiert. Es wurden keine A1-, yesss!-, Educom- oder Firebase-Server, -Konten oder -Infrastruktur geprüft.

```
C1 -- google_api_key, firebase_database_url: [REDACTED IN PUBLIC REPORT -- disclosed
    privately to A1 Telekom Austria/yesss! in R1]
   Firebase-Projektname: "educom-6e0db"

H1 -- android.permission.ACCESS_ADSERVICES_ATTRIBUTION
   android.permission.ACCESS_ADSERVICES_AD_ID
   com.google.android.gms.permission.AD_ID

H2 -- com.google.firebase.provider.FirebaseInitProvider (initOrder=100)
```

Offenlegungs-Zeitlinie (Disclosure Timeline) & Ergebnis

2026-06-30 Einzige gesendete Nachricht: Erstmeldung an datenschutz@a1.at und security@a1.at, CC presse@a1.at, österreichische DSB, EDPS. Embargo: 2026-09-28. REF YESSS-2026-R1-001. Kein Bounce.

2026-06-30 bis 2026-10-17 Keine Folgenachricht gesendet. Keine Antwort jeder Art empfangen.

2026-09-28 Embargo-Datum erreicht, wie am 2026-06-30 einmalig genannt. Korresponde nz-Stand: eine RFI-IRFOS-Nachricht, null Antworten jeder Art.

2026-10-17 Dieser Bericht veröffentlicht, 19 Tage nach dem Embargo-Datum.

Restrisiko & Empfehlungen (Residual Risk)

C1 — Sofort: hartcodierten Firebase-Key rotieren; die Subverarbeiter-Beziehung zur unter ”educom-6e0db” registrierten Infrastruktur in der Datenschutzerklärung nach Art. 13/Art. 28 DSGVO transparent ausweisen.

H1 — Kurzfristig: eine dokumentierte Art. 6(1)-Rechtsgrundlage für die Kombination von Telco-Nutzungsdaten mit Werbe-Attribution schaffen oder ACCESS_ADSERVICES_ATTRIBU TION entfernen.

H2 — Kurzfristig: FirebaseInitProvider hinter die Einwilligungsentscheidung legen.

Alle Befunde — einen überwachten Intake-Pfad für Sicherheits- und Datenschutzmeldungen an datenschutz@a1.at und security@a1.at einrichten: eine einzige schriftliche Meldung über 109 Tage ohne jede Antwort ist ein eigenständiger Prozessfehler, unabhängig von den drei technischen Befunden dieses Berichts.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria Alle Befunde beruhen auf statischer Analyse der veröffentlichten Anwendung mittels öffentlich verfügbarer Werkzeuge. Es wurden keine A1-, yesss!-, Educom- oder Firebase-Server, -Konten oder -Infrastruktur geprüft. Technische Nachweise sind unter Chain of Custody archiviert und werden Aufsichtsbehörden auf Anfrage zur Verfügung gestellt. Forschung durchgeführt gemäß ISO/IEC 29147, der Freiheit der Wissenschaft (Art. 17 StGG) und DS-GVO Art. 89. REF YESSS-2026-R1-001.